

|                                                              |                                                                                                                                                                                                                                                                 |
|--------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FACILITY_NAME, FACILITY_ADDRESS (KMHFL: FACILITY_KMHFL_CODE) |                                                                                                                                                                                                                                                                 |
| Controller                                                   |                                                                                                                                                                                                                                                                 |
| Processor                                                    | Lovable (managed hosting), Supabase (project tgynjasgnerucrlwedui), AegisCare Development Team (support)                                                                                                                                                        |
| Legal framework                                              | Kenya Data Protection Act, 2019 (No. 24 of 2019); Data Protection (General) Regulations, 2021; Digital Health Act, 2023; Social Health Insurance Act, 2023; Health Act, 2017; Digital Health (Data Exchange Component) Regulations, 2025; ODPC guidance on DPIA |
| DPO                                                          | DPO_NAME ( <b>PENDING</b> appointment)                                                                                                                                                                                                                          |
| Date of assessment                                           | 2026-08-12 (draft)                                                                                                                                                                                                                                              |
| Review due                                                   | 2027-08-12 or on material change                                                                                                                                                                                                                                |
| Related documents                                            | DOC-1 (Architecture), DOC-3 (Privacy Policy), DOC-6 (Security Policy), DOC-7 (Gap Analysis)                                                                                                                                                                     |

## Section 1 — Purpose & Scope of Assessment

1.1 This DPIA assesses the processing of personal and special-category (health) data by AegisCare HMS at FACILITY\_NAME, in line with s.32 of the Kenya Data Protection Act, 2019 and ODPC guidelines, to:

- identify and evaluate risks to the rights and freedoms of data subjects;
- verify necessity and proportionality of the processing;
- document mitigations implemented in the system;
- support the DHA certification submission (Form HMIS 4) and ODPC registration.

1.2 Scope: all personal data processed through the AegisCare deployment — patient demographics and identifiers, clinical records, billing/insurance data, consent records, audit trails, and staff data — from collection at registration through retention, sharing (DHA HIE, SHA, MOH), and archival. Out of scope: processing by third-party systems not yet connected (live integrations are pending credentials; each will be re-assessed on activation).

## Section 2 — Description of Processing

### 2.1 Data subjects

Patients (adults, minors via guardians), staff users, and (in mortuary records) deceased persons' representatives.

### 2.2 Data categories (with system evidence)

| Category           | Data                                                                                                      | Storage (tables/columns)                                                                                                                            |
|--------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Identity           | name, DOB, sex, national ID/passport/birth certificate, photo                                             | patients (first_name, date_of_birth, national_id, national_id_type, photo_url)                                                                      |
| Health             | vitals, history, ICD-11 diagnoses, notes, lab results, radiology findings, prescriptions, administrations | encounters.vitals/history/diagnoses, encounter_diagnoses, clinical_notes, lab_results, radiology_results, prescriptions, medication_administrations |
| SHA/insurance      | member number, fund type, claims, preauth, notification number                                            | patients.sha_*, encounters.sha_*, sha_claims (+items/packages), sha_benefit_packages, sha_tariffs                                                   |
| Client             | CR ID, verified identity flags                                                                            | patients.cr_number, identity_verified*                                                                                                              |
| Registry Financial | invoices, payments, coverage                                                                              | invoices, invoice_line_items, invoice_payments, insurance_providers, contracted_prices                                                              |
| Consent            | OTP evidence, consent decisions                                                                           | consent_otps (hashes), patient_consent                                                                                                              |
| Contact            | phone, email, addresses                                                                                   | patients                                                                                                                                            |
| Staff              | names, roles, council registrations, access grants                                                        | profiles, user_roles, role_permissions, user_room_access                                                                                            |
| Operations         | audit events, SHR transmission metadata, room movements, mortuary                                         | audit_log, audit_log_archive, shr_transmission_log, encounter_room_visits, mortuary_records                                                         |

2.3 Purposes

Provision of healthcare; billing and SHA/insurance claims; statutory MOH reporting; HIE data sharing (with consent); safety and quality (critical results, dual verification, discharge gating); audit and accountability.

2.4 Processing operations

Collection (registration/consultation), storage (Supabase), structuring (ICD-11 coding, MOH tagging), use (clinical workflows), disclosure (queued sharing to DHA/SHA — consent-gated), archival (audit archiving), and deletion (limited; subject to legal retention).

2.5 Recipients

Facility staff (role-limited), FACILITY\_NAME (controller), processors (Lovable, Supabase), and — on activation — DHA HIE, SHA, IPRS, Kenya HWR, WHO (ICD-11 queries, no identifiers), NLMIS/KEMSA (non-personal commodity data), MOH/KHIS (aggregates).

Section 3 — Necessity & Proportionality

3.1 Necessity. Each processing purpose maps to a legal basis (DOC-3 §3): healthcare contract/necessity; SHA statutory claims with s.48 consent; MOH statutory reporting; DHA-mandated HIE exchange with explicit consent; audit under the Data Exchange Component Regulations 2025.

3.2 Proportionality measures implemented:

- Minimisation: only the columns needed for care/billing/reporting are collected; moh\_\* aggregates are de-identified counts; FHIR payloads include only encounter-scoped data.

- Purpose limitation: separate consent types (general\_treatment, hie\_data\_sharing, sha\_claim, preauth, shr\_access) in consent\_otps / patient\_consent; HIE sync is consent-gated in claims-dispatcher.
- Access limitation: 19-role RBAC + RLS + room-level grants (user\_room\_access); admin-only provisioning.
- Retention limitation: audit hot/cold archiving (2-year hot, 20-year archive); clinical retention per law; OTPs 10-minute validity, hashes only.
- Transparency: DOC-3 Privacy Policy, consent slips, SHR access notifications (trg\_shr\_access\_notification).

3.3 Alternatives considered: a paper-only workflow (rejected — cannot meet SHA electronic claims or DHA HIE mandates); a multi-tenant shared deployment (rejected — Model A per-facility isolation chosen to prevent cross-facility exposure, docs/facility-onboarding.md).

## Section 4 — Risk Identification

Rating scale: Likelihood (L) and Impact (I): High/Medium/Low. Residual risk after mitigation: High/Medium/Low.

### Risk 1 — Unauthorised access to patient records

- Description: staff or external parties view records beyond their role.
- L / I: Medium / High.
- Current mitigation (evidence): RLS on all clinical tables via is\_approved(auth.uid()) (134 policy statements); 19-role RBAC (src/lib/roles.ts); role\_permissions + user\_has\_permission(); room-level grants user\_room\_access/can\_access\_room(); 30-minute session timeout (app-shell.tsx); admin-only user management (admin-users.functions.ts + assertAdmin); audit\_log records every access-adjacent change with changed\_by.
- Residual risk: Medium — mitigated but not eliminated; monitor via admin.audit-log.tsx and quarterly access reviews (△ GAP: formalise quarterly access reviews in writing).

### Risk 2 — Data breach via API

- Description: exposure through the REST/edge-function surface.
- L / I: Medium / High.
- Current mitigation: verify\_jwt = true on all five edge functions (supabase/config.toml); claims-dispatcher re-validates the caller via supabase.auth.getUser(); anon EXECUTE revoked on 8 SECURITY DEFINER functions; RLS enforced on all PostgREST reads; CVE remediation (seroval ^1.5.4, xlsx removed); publishable (anon) key is the only client-side credential.
- Residual risk: Medium — pending: restrict edge-function CORS to application origins (DOC-6 §7.4); re-assess when DHA/SHA credentials activate.

### Risk 3 — SHA claims data exposure

- Description: member numbers, claims, or preauth data exposed or misused.
- L / I: Low / High.

- ```
DOC = enforce_encounter_lock(); insurance_per_visit_limits_enforced
documents
enforce_insurance_visit_limit()
```

- Residual risk: Medium — mitigated by detection, not prevention; recommend staff privacy training records (⚠️ GAP: training log).

## Risk 8 — Data retention beyond necessity

- Description: keeping data longer than required.
- L / I: Medium / Medium.
- Current mitigation: OTP 10-minute expiry + hashes; audit archiving at 2 years with defined 20-year retention; MOH aggregates kept for reporting history; clinical records retained per statutory minimum (DOC-3 §6); erasure requests assessed per DOC-3 §7 (deletion limitations apply to medical records).
- Residual risk: Low — once the facility confirms FACILITY\_CLINICAL\_RETENTION\_YEARS and the deletion procedure is operationalised.

## Risk summary table

| # | Risk                       | L | I | Mitigation (evidence)                                                  | Residual |
|---|----------------------------|---|---|------------------------------------------------------------------------|----------|
| 1 | Unauthorised record access | M | H | RLS, RBAC, room grants, timeout, audit                                 | Medium   |
| 2 | API data breach            | M | H | JWT verification, revoked anon EXECUTE, CVE fixes                      | Medium   |
| 3 | SHA claims exposure        | L | H | RLS on claims, OTP consent, secrets policy                             | Low      |
| 4 | National ID misuse         | L | H | Consent-gated verification, storage encryption, coded FHIR identifiers | Low      |
| 5 | Audit tampering            | L | H | Append-only RLS + SECURITY DEFINER + archive runs                      | Low      |
| 6 | HIE data sharing           | M | M | Explicit consent gate, access notifications, transmission log          | Medium   |
| 7 | Insider threat             | M | H | Least privilege, snapshots, break-glass alerts, locks                  | Medium   |
| 8 | Over-retention             | M | M | Expiry rules, archiving schedule, erasure procedure                    | Low      |

## Section 5 — Consultation

5.1 Internal: facility management, records officer, ICT/technical lead, nursing and clinical leads, accounts/insurance desk — to be documented with names and dates (⚠️ GAP: record consultation minutes and attach).

5.2 External (planned/ongoing):

- ODPC — registration (📄 PENDING) and DPIA filing where required;
- DHA — certification process (Form HMIS 4) and HIE onboarding;
- SHA — provider registration and claims API onboarding;
- Data subjects — privacy notice (DOC-3) displayed at registration.

5.3 Processing of children's data: handled through guardian consent (sha\_relationship\_to\_principal dependent relationships; DHA dependant consent flow planned); no targeted profiling of children.

## Section 6 — DPO Sign-off

|                         | Name                        | Signature | Date |
|-------------------------|-----------------------------|-----------|------|
| Data Protection Officer | DPO_NAME ( <b>PENDING</b> ) |           |      |
| Facility In-Charge      | _____                       |           |      |
| Technical Lead          | _____                       |           |      |

DPO opinion: (to be completed — draft assessment approved subject to the outstanding items in DOC-7 §6 and the gaps recorded in Section 4.)

## Section 7 — Review Schedule

### 7.1 Triggers for early review:

- activation of any live integration (IPRS, SHA, AfyaLink, HWR, SMS, M-Pesa);
- biometric verification activation;
- change in retention policy or legal framework;
- any personal-data breach;
- change of processor or hosting arrangement (e.g., transfer to the facility-owned Supabase project).

7.2 Scheduled reviews: annually (next due 2027-08-12), aligned with the Security Policy review (DOC-6) and before each DHA certification renewal.

### 7.3 Version history:

| Version   | Date       | Change                              | Author                     |
|-----------|------------|-------------------------------------|----------------------------|
| 1.0 draft | 2026-08-12 | Initial DPIA for certification pack | AegisCare Development Team |

\*End of DOC-2.\*